UNIVERSITÀ DI PARMA — DIPARTIMENTO DI INGEGNERIA E ARCHITETTURA

Riassunto Esteso: Crittografia Simmetrica (Secret Key Cryptography)

Corso di Cybersecurity (A.A. 2025/2026) | Docente: Prof. Luca Veltri

1. Introduzione e Servizi di Sicurezza

La **crittografia simmetrica** (nota anche come crittografia a chiave segreta, convenzionale o a singola chiave) è lo studio e l'applicazione delle tecniche matematiche atte a garantire la sicurezza delle comunicazioni e dei dati in presenza di avversari terzi. Rappresenta lo strumento fondamentale per la sicurezza informatica e supporta quattro servizi essenziali:

- **Riservatezza (Confidentiality):** Garantisce che l'informazione sia accessibile unicamente alle parti autorizzate.
- **Integrità dei dati (Data Integrity):** Assicura che i dati non vengano alterati, manipolati o danneggiati in modo non autorizzato durante la trasmissione o l'archiviazione.
- **Autenticazione (Authentication):** Verifica l'identità della sorgente dei dati o delle parti comunicanti.
- **Non-ripudio (Non-repudiation):** Impedisce a un'entità di negare la paternità di un'azione o di un messaggio inviato.

Classificazione dei Principali Algoritmi Crittografici

Tipologia	Caratteristiche Chiave	Applicazioni Tipiche
Crittografia Simmetrica	Mittente e destinatario condividono un'unica chiave segreta (k).	Cifratura di dati a riposo (storage) o in transito ad alta velocità.
Funzioni Hash & MAC	Trasformazioni unidirezionali da messaggi a lunghezza variabile a stringhe a lunghezza fissa. Il MAC include una chiave segreta.	Verifica dell'integrità e autenticazione dei messaggi.
Crittografia Asimmetrica	Coppia di chiavi opposte: una chiave pubblica e una chiave privata.	Scambio chiavi, firme digitali, autenticazione iniziale.

2. Il Modello del Cifrario Simmetrico e il Principio di Kerckhoffs

Nel modello di cifratura simmetrica, un messaggio in chiaro (m) viene trasformato in un testo cifrato (c) mediante un algoritmo di cifratura E parametrizzato da una chiave segreta k. Il destinatario applica l'algoritmo di decifratura D utilizzando la medesima chiave per recuperare m.

> **Formulazione Matematica:**
> • Cifratura: $c = E(k, m) = E_k(m)$ (può essere deterministica o randomizzata)
> • Decifratura: $m = D(k, c) = D_k(c) = D_k(E_k(m))$ (necessariamente deterministica)

- **Canale Sicuro:** Il modello presuppone l'esistenza di un canale sicuro o di un metodo idoneo per la generazione e distribuzione iniziale della chiave k tra le parti.
- **Keyspace (Spazio delle Chiavi):** Insieme di tutte le possibili chiavi utilizzabili. Ad esempio, una chiave a 256 bit genera uno spazio di $2^{256} \approx 10^{77}$ valori possibili. La robustezza teorica è proporzionale alla lunghezza della chiave (40 bit è debole, 128 bit è forte, 256 bit offre sicurezza elevatissima).

Il Principio di Kerckhoffs (1883)

Formulato da Auguste Kerckhoffs, stabilisce che *la sicurezza di un sistema crittografico deve dipendere esclusivamente dalla segretezza della chiave e non dalla segretezza dell'algoritmo*. In pratica, gli algoritmi moderni (es. AES, DES) sono pubblici e sottoposti a scrupolosa analisi da parte della comunità scientifica; la sicurezza viene mantenuta cambiando unicamente la chiave segreta quando variano i partecipanti autorizzati.

3. Cifrari Classici e Storici

Prima dell'era dei computer, la crittografia si basava su tecniche di sostituzione e trasposizione operanti su caratteri alfabetici.

3.1 Cifrari di Sostituzione Monoalfabetica

Sostituiscono ciascun simbolo del testo in chiaro con un altro simbolo in base a una regola fissa.

- **Cifrario di Cesare:** Il più antico cifrario di sostituzione documentato. Effettua uno scorrimento (shift) fisso di 3 posizioni: $C = (M + 3) \mod 26$.
- **Shift Cipher (Cifrario a Scorrimento Generico):** Chiave $k \in \{0, 1, ..., 25\}$. Formula: $C = (M + k) \mod 26$. Caso particolare: **ROT13** ($k = 13$), in cui la funzione di cifratura coincide con quella di decifratura ($E(X) = D(X)$). Vulnerabile ad attacchi a forza bruta avendo soltanto 26 chiavi possibili.
- **Sostituzione Monoalfabetica Generale:** Permuta arbitrariamente le 26 lettere. Lo spazio delle chiavi ammonta a $26! \approx 4 \times 10^{26}$. Nonostante l'elevato numero di chiavi, è **estremamente debole** ed è facilmente violabile tramite la **criptanalisi statistica della frequenza** (scoperta dagli studiosi arabi nel IX secolo), sfruttando la ridondanza naturale delle lingue (frequenza di singole lettere come 'E' e 'T' in inglese, digrammi come "th", e trigrammi).

3.2 Cifrari di Sostituzione Polialfabetica

Utilizzano molteplici alfabeti di sostituzione monoalfabetica in sequenza, guidati da una parola chiave che definisce quale alfabeto applicare a ciascun carattere del messaggio.

- **Cifrario di Vigenère (1586) / Bellaso (1553):** Basato sulla tavola di Vigenère (Tabula Recta). Data una chiave di lunghezza t: $C_i = (M_i + K_{i \mod t}) \mod 26$. Oscura le frequenze delle singole lettere del testo chiaro, rendendo la criptanalisi più complessa.
- **Criptanalisi di Vigenère:** Sfrutta la natura ripetitiva della chiave. Si determina prima la lunghezza della chiave t (metodo Kasiski o indice di coincidenza), riducendo il problema alla rottura di t cifrari a scorrimento indipendenti analizzabili individualmente.

3.3 Cifrari Elettro-Meccanici e Macchine a Rotori

Utilizzati ampiamente durante la Seconda Guerra Mondiale (es. **Enigma** tedesca, **Hagelin** alleata, **Purple** giapponese). Impiegano una serie di cilindri/rotori rotanti. Ogni pressione di un tasto fa avanzare uno o più rotori, cambiando la sostituzione ad ogni lettera e implementando un cifrario polialfabetico dinamico ad altissimo numero di alfabeti (es. 3 rotori forniscono $26^3 = 17.576$ alfabeti).

3.4 Cifrari di Trasposizione e Cifrari di Prodotto

- **Cifrari di Trasposizione:** Riorganizzano l'ordine dei caratteri (permutazione) senza alterare i simboli usati. Mantengono inalterata la distribuzione delle frequenze originaria. Esempio: *Row Transposition Cipher* (scrittura per righe, lettura per colonne riordinate secondo una chiave).
- **Cifrari di Prodotto:** Combinano in successione più sostituzioni e trasposizioni. Costituiscono il ponte concettuale verso i cifrari a blocco moderni.

4. Teoria dell'Informazione e Segretezza Perfetta (Claude Shannon)

Nel 1949, Claude Shannon pubblicò il lavoro fondamentale *"Communication Theory of Secrecy Systems"*, fondando la trattazione matematica rigorosa della crittografia come problema di dispersione dell'informazione.

Sicurezza Pratica vs Sicurezza Teorica

- **Sicurezza Pratica (Computazionale):** Violabile in linea teorica, ma la rottura richiede uno sforzo computazionale irrealizzabile con le risorse disponibili.
- **Sicurezza Teorica (Incondizionata / Perfetta):** Impossibile da violare anche disponendo di tempo e potenza di calcolo illimitati. Il testo cifrato non rivela alcuna informazione sul testo chiaro.

Modellazione Probabilistica

Shannon tratta il messaggio M e la chiave K come variabili casuali indipendenti, definendo la trasformazione probabilistica $(M, K) \to C$:

- **Probabilità A Priori:** $Pr(M = m)$ — la statistica della sorgente dei messaggi prima di osservare il cifrato.
- **Probabilità A Posteriori:** $Pr(M = m \mid C = c)$ — la conoscenza aggiornata dell'avversario dopo aver intercettato il cifrato c.

> **Definizione Formale di Segretezza Perfetta:**
> Un sistema possiede segretezza perfetta se e solo se l'osservazione del testo cifrato non altera la conoscenza dell'avversario sul messaggio:
>
> $$Pr(M = m \mid C = c) = Pr(M = m) \quad \forall m, c$$
>
> **Teorema:** Un sistema ha segretezza perfetta $\Leftrightarrow Pr(C = c \mid M = m) = Pr(C = c) \quad \forall m, c$ (la distribuzione dei cifrati è del tutto indipendente dal messaggio).

Entropia e Limite di Shannon (Shannon Bound)

L'entropia $H(X) = -\sum Pr(x) \log_2 Pr(x)$ misura l'incertezza o contenuto informativo medio. L'equivocazione $H(M \mid C)$ misura l'incertezza residua sul messaggio dopo aver osservato il cifrato.

- Un crittosistema ha segretezza perfetta se e solo se $H(M) = H(M \mid C)$.
- **Limite Superiore di Shannon:** $H(M \mid C) \leq H(K)$. Ne consegue che per ottenere la segretezza perfetta occorre che $H(K) \geq H(M)$ (l'entropia della chiave deve essere maggiore o uguale all'entropia del messaggio). In particolare, lo spazio delle chiavi deve essere grande almeno quanto lo spazio dei messaggi: $|K| \geq |M|$.

5. One-Time Pad (OTP)

Brevettato da Vernam nel 1919 (e descritto da Miller nel 1882), l'OTP è l'esempio principe di cifra a segretezza perfetta.

- **Funzionamento Binario:** Cifratura $C_i = M_i \oplus K_i$; Decifratura $M_i = C_i \oplus K_i$ (operazione XOR bit a bit).
- **Requisiti per la Segretezza Perfetta (Dimostrati da Shannon):**
  1. La chiave deve essere lunga almeno quanto il messaggio da cifrare.
  2. La chiave deve essere generata in modo puramente casuale (distribuzione uniforme).
  3. La chiave deve essere usata **una sola volta** (One-Time) e distrutta.
- **Limiti Pratici:** Nonostante l'inviolabilità teorica, l'OTP presenta enormi complessità gestionali: la chiave è grande quanto la totalità dei dati trasmessi, la distribuzione deve avvenire su canale protetto e l'archiviazione sicura delle chiavi è onerosa.

6. Primitive Crittografiche, Cifrari a Flusso e Cifrari a Blocco

Primitive Fondamentali

- **Keyed Functions:** $F_k: \{0,1\}^n \to \{0,1\}^m$ (deterministiche, senza stato).
- **Keyed Permutations:** $P_k: \{0,1\}^n \to \{0,1\}^n$ (permutazioni biettive).
- **Unkeyed Compression Functions:** $C: \{0,1\}^a \to \{0,1\}^b$ con $a > b$.
- **Stream Generators:** $G: \{0,1\}^* \to \{0,1\}^*$.

Cifrari a Flusso (Stream Ciphers)

Processano il messaggio elemento per elemento (bit o byte) combinandolo con uno *keystream* pseudocasuale. La maggior parte si basa su **CSPRNG** (Cryptographically Secure Pseudo-Random Number Generator), i quali garantiscono:

- *Resistenza al Next-Bit Guessing:* Impossibile prevedere il bit $k+1$ conoscendo i primi k bit.

- *Resistenza allo Stato Compromesso:* Impossibile ricostruire i bit passati anche se lo stato interno viene rivelato.

Esempio — ChaCha20 (Bernstein, 2008): Cifrario a flusso a 20 round operante su chiave a 256 bit, contatore a 32 bit e nonce/IV a 96 bit. Genera blocchi di keystream da 512 bit (64 byte).

Cifrari a Blocco (Block Ciphers)

Trattano il testo chiaro in blocchi di dimensione fissa n (es. 64 o 128 bit). Anziché memorizzare tabelle di sostituzione enormi (impraticabili poiché per $n=64$ servirebbero petabyte di memoria), il cifrario a blocco viene costruito combinando operazioni elementari con una chiave di lunghezza m (2^m trasformazioni possibili).

> **Effetto Valanga (Avalanche Effect):** Proprietà fondamentale dei cifrari a blocco per cui la variazione di un singolo bit nel testo in chiaro o nella chiave comporta il cambiamento di circa il 50% dei bit del testo cifrato in uscita.

7. Advanced Encryption Standard (AES / Rijndael)

Selezionato da NIST nel 2000 e standardizzato nel 2001 (FIPS PUB 197) per sostituire il DES, AES è stato sviluppato dai crittografi belgi Joan Daemen e Vincent Rijmen.

Caratteristiche Architetturali

- **Struttura:** Rete di Sostituzione-Permutazione (SP-Network), non Feistel.
- **Dimensione Blocco:** Fisso a 128 bit (16 byte), rappresentato come una matrice 4×4 di byte denominata *State*.
- **Dimensioni Chiave e Round:**
  - AES-128: Chiave a 128 bit → 10 round.
  - AES-192: Chiave a 192 bit → 12 round.
  - AES-256: Chiave a 256 bit → 14 round.

Le 4 Operazioni di Round in AES

1. **SubBytes (Sostituzione):** Sostituzione non lineare di ciascun byte dello stato tramite la S-Box di Rijndael, derivata dall'inverso moltiplicativo nel campo finito $GF(2^8)$. Fornisce la *confusione* nel cifrario.
2. **ShiftRows (Permutazione):** Trasposizione ciclica delle righe dello stato. La riga 0 non viene modificata, la riga 1 trasla a sinistra di 1 byte, la riga 2 di 2 byte, la riga 3 di 3 byte. Fornisce la *diffusione*.
3. **MixColumns (Combinazione Lineare):** Moltiplicazione matriciale delle colonne dello stato operata in $GF(2^8)$ modulo x^4+1. Ogni byte finale è funzione di tutti e 4 i byte della colonna originale. (Omessi nell'ultimo round).
4. **AddRoundKey:** XOR bit a bit dello stato con la subkey di round prodotta dall'algoritmo di *KeyExpansion*.

Sicurezza di AES: Approvato dalla NSA per informazioni TOP SECRET. Gli unici attacchi teorici a pieno round (2011) riducono il tempo di calcolo di un fattore 4 rispetto alla forza bruta ($2^{126.1}$ operazioni per AES-128). Gli unici attacchi pratici efficaci sono quelli basati su *Side-Channel* (canali collaterali fisici).

8. Cifratura Multipla e Triple DES (3DES)

Per incrementare la sicurezza computazionale è possibile applicare lo stesso algoritmo più volte con chiavi differenti: $c = E_{K_n}(...E_{K_1}(m))$.

Doppia Cifratura e Attacco Meet-in-the-Middle

Cifrare due volte con due chiavi distinte $c = E_{K2}(E_{K1}(m))$ **non raddoppia la sicurezza**. L'attacco **Meet-in-the-Middle** sfrutta la relazione $X = E_{K1}(M) = D_{K2}(C)$: cifrando M con tutte le possibili chiavi e memorizzando i risultati, e decifrando C confrontando i valori, la rottura richiede solo $O(2^{n+1})$ operazioni e $O(2^n)$ memoria.

Triple DES (3DES / TDEA)

Supera l'attacco Meet-in-the-Middle applicando tre fasi: $c = E_{K3}(D_{K2}(E_{K1}(m)))$.

- **Opzione 1 (3 chiavi distinte):** Chiavi $(k1, k2, k3)$ → lunghezza totale 168 bit.
- **Opzione 2 (2 chiavi distinte):** Chiavi $(k1, k2, k1)$ → lunghezza totale 112 bit.
- **Opzione 3 (1 chiave):** $k1 = k2 = k3$ → equivalente al DES classico a 56 bit.

9. Modi di Funzionamento dei Cifrari a Blocco (Modes of Operation)

I cifrari a blocco elaborano blocchi di dimensione fissa. Per cifrare messaggi di lunghezza arbitraria occorre definire appositi modi di funzionamento.

9.1 Padding

Se la lunghezza del messaggio non è multiplo del blocco, si applica un padding:

- **Bit Padding (ISO/IEC 7816-4):** Aggiunge il bit '1' seguito da bit '0'.
- **ANSI X.923:** Riempie di zeri e inserisce nell'ultimo byte il conteggio dei byte di padding.
- **PKCS#7 / PKCS#5 (RFC 5652):** Il valore di ciascun byte aggiunto è pari al numero totale di byte inseriti (es. 5 byte di pad → `05 05 05 05 05`).

9.2 Confronto dei Principali Modi di Funzionamento

Modo	Formula di Cifratura	Vantaggi	Svantaggi / Rischi
ECB (Electronic Codebook)	$C_i = E_K(M_i)$	Semplice, elaborazione indipendente dei blocchi.	Blocchi uguali producono cifrati uguali. Preserva i pattern (es. contorni immagini). Vulnerabile a riordinamento. **Sconsigliato**.
CBC (Cipher Block Chaining)	$C_i = E_K(M_i \oplus C_{i-1})$ $C_0 = IV$	Nasconde i pattern, effetto valanga in avanti.	Modifica dell'IV altera M_1; modifica di C_i altera M_{i+1}. Vulnerabile ad attacchi *Padding Oracle*. Richiede MAC.
OFB (Output Feedback)	$O_i = E_K(O_{i-1})$ $C_i = M_i \oplus O_i$	Keystream calcolabile in anticipo. Nessuna propagazione d'errore sui bit. Nessun padding.	Mai riutilizzare la coppia (Key, IV). Se il testo chiaro è noto, lo keystream viene estratto immediatamente.
CFB (Cipher Feedback)	$C_i = M_i \oplus E_K(C_{i-1})$ $C_0 = IV$	Usa l'algoritmo di cifratura anche in decifratura. Resincronizzazione automatica su byte persi.	Propagazione degli errori al blocco successivo. Keystream non calcolabile in anticipo.
CTR (Counter Mode)	$T_i = IV \parallel i$ $C_i = M_i \oplus E_K(T_i)$	**Parallelizzazione totale**, calcolo anticipato, accesso casuale diretto ai blocchi.	Richiede contatori strettamente unici per evitare il riuso dello keystream.

10. Modelli di Minaccia, Attacchi e Attacchi Oracle

Modelli di Minaccia (Threat Models)

- **Ciphertext-Only Attack (KCA):** L'attaccante dispone unicamente di testi cifrati intercettati. Il caso più difficile.
- **Known-Plaintext Attack (KPA):** L'attaccante conosce una o più coppie testo chiaro / testo cifrato $\langle m, c \rangle$.
- **Chosen-Plaintext Attack (CPA):** L'attaccante può scegliere testi in chiaro arbitrari e ottenerne i relativi testi cifrati dal sistema.
- **Chosen-Ciphertext Attack (CCA):** L'attaccante può scegliere testi cifrati arbitrari e ottenerne le relative decifrature.

Tipologie Generali di Attacco

- **Forza Bruta (Exhaustive Search):** Ricerca esaustiva su tutto lo spazio delle chiavi. Per una chiave a 128 bit a 10^6 decifrazioni/µs servono 1.1×10^{19} anni.
- **Criptanalisi:** Sfrutta proprietà matematiche/statistiche dell'algoritmo (es. Criptanalisi Differenziale, Criptanalisi Lineare).
- **Attacchi per Canale Collaterale (Side-Channel Attacks):** Sfruttano fughe di informazioni dall'implementazione fisica (tempi di esecuzione, consumo di potenza elettrica, radiazioni elettromagnetiche/TEMPEST).

Attacchi Oracle

Un *Oracolo* è un sistema/servizio con cui l'attaccante interagisce, in grado di rispondere a query (es. cifrando/decifrando o confermando la validità di un'operazione) senza rivelare la chiave segreta.

1. ECB Encrypting Oracle Attack:
Se un oracolo cifra $E_K(m \parallel \text{secret})$ in modalità ECB, inviando un messaggio m lungo $N-1$ byte (es. 15 byte), l'attaccante spinge il primo byte del segreto nella 16ª posizione del primo blocco. Provando i 256 possibili byte per la 16ª posizione, individua il primo byte del segreto per confronto. Ripetendo il processo byte per byte, l'intero segreto viene ricostruito.

2. Padding Oracle Attack su CBC:
Punta alla verifica del padding PKCS#7 durante la decifratura in CBC. Se il server rivela (tramite messaggi d'errore differenti o tempi di risposta) se il unpadding è fallito o riuscito, l'attaccante modifica i byte di C_1. Poiché $M_2[15] = D_K(C_2)[15] \oplus C_1[15]$, variando $C_1[15]$ finché l'oracolo accetta il padding (valore valido `0x01`), si ricava con certezza il byte del messaggio chiaro $M_2[15]$. Ricostruisce a ritroso l'intero testo in chiaro senza conoscere la chiave K.
Mitigazioni: Risposte di errore in tempo costante (constant-time responses) e impiego di algoritmi con Cifratura Autenticata (Authenticated Encryption - AEAD).